Proyecto práctico de Seguridad Informática

Simulación de phishing, monitoreo y reducción de riesgos

1. Objetivo general

Implementar un escenario controlado de simulación de phishing en un laboratorio, monitorear los intentos de autenticación mediante OWASP ZAP y los registros de los servidores web Apache y NGINX, implementar un mecanismo de bloqueo temporal después de tres intentos fallidos consecutivos y evaluar la reducción de los riesgos mediante controles fundamentados en ISO/IEC 27005 y NIST Cybersecurity Framework 2.0.

2. Actividades del proyecto

2.1. Investigación y preparación del laboratorio

1. Investigar dos casos reales documentados de phishing mediante códigos QR o enlaces acortados. Explicar el mecanismo utilizado, los activos afectados y las posibles consecuencias.
2. Identificar los activos, amenazas, vulnerabilidades e impactos relacionados con los casos investigados.
3. Preparar un laboratorio aislado que incluya:
    - Dos equipos de usuario para realizar las pruebas.
    - Un servidor web Apache.
    - Un servidor web NGINX.
    - Una máquina de monitoreo con OWASP ZAP.
4. Implementar en ambos servidores una aplicación de prueba con un formulario de inicio de sesión y una cuenta ficticia. La funcionalidad debe ser equivalente para permitir la comparación de los resultados.
5. Diseñar un mensaje de phishing simulado que contenga un enlace o código QR dirigido exclusivamente a la aplicación del laboratorio.

Condición: el enlace o QR no debe conducir a sitios externos de captura de credenciales ni utilizar cuentas o datos personales reales.

2.2. Simulación y monitoreo

1. Instalar y configurar OWASP ZAP en la máquina de monitoreo.
2. Capturar, mediante OWASP ZAP, las solicitudes y respuestas HTTP generadas durante las pruebas de autenticación.
3. Ejecutar intentos de inicio de sesión autorizados utilizando datos ficticios, incluidos intentos fallidos y exitosos.

4. Recopilar los registros de Apache, NGINX y la aplicación de prueba.
5. Obtener capturas de pantalla que evidencien la configuración del laboratorio, las solicitudes HTTP observadas y los registros generados.

2.3. Implementación de controles y matriz de riesgos

1. Implementar un mecanismo de registro de eventos de autenticación que permita identificar, como mínimo:
    - Fecha y hora del intento.
    - Usuario ficticio involucrado.
    - Resultado de la autenticación.
    - Dirección IP de origen, cuando esté disponible.
    - Estado de bloqueo de la cuenta.
2. Implementar el bloqueo temporal de la cuenta después de tres intentos fallidos consecutivos.
3. Verificar que la cuenta no permita iniciar sesión durante el período de bloqueo, incluso si se introduce la contraseña correcta.
4. Elaborar una matriz de riesgos inicial a partir de los activos y escenarios identificados.
5. Seleccionar controles de seguridad y justificar su relación con ISO/IEC 27005 y las funciones pertinentes de NIST Cybersecurity Framework 2.0.
6. Actualizar la matriz de riesgos después de implementar los controles y comparar el riesgo inicial con el riesgo residual.

2.4. Verificación y presentación

1. Repetir las pruebas de autenticación antes y después de implementar los controles.
2. Comparar los resultados de Apache y NGINX en las mismas condiciones de prueba.
3. Verificar que los registros permitan reconstruir la secuencia de los intentos de acceso y comprobar el bloqueo.
4. Presentar los resultados, las evidencias técnicas, las limitaciones del laboratorio y las recomendaciones de mejora.

3. Estructura del informe técnico

3.1. Portada

Incluir institución, asignatura, título del proyecto, integrantes, docente y fecha.

Título del informe: *Monitoreo de seguridad: simulación de phishing, análisis de eventos y reducción de riesgos*.

3.2. Objetivo

Indicar el propósito de la práctica y los resultados técnicos que se pretende alcanzar.

3.3. Antecedentes y fundamentos teóricos

Desarrollar los siguientes temas:

1. **ISO/IEC 27001 e ISO/IEC 27005:** explicar brevemente la finalidad de cada norma y su relación con la gestión de riesgos de seguridad de la información.
2. **NIST Cybersecurity Framework 2.0:** describir sus seis funciones —Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar— e identificar las que se relacionan con el proyecto.
3. **OWASP ZAP:** explicar qué es, para qué sirve, sus principales características técnicas y los requisitos necesarios para su funcionamiento.
4. **Casos reales de phishing:** documentar dos incidentes basados en códigos QR o enlaces acortados. Incluir fuente, mecanismo del ataque, activos afectados, consecuencias y controles que podrían reducir el riesgo.
5. **Comparación de servidores web:** presentar un cuadro comparativo entre Apache HTTP Server y NGINX, considerando características técnicas, configuración, registros, requisitos de funcionamiento y diferencias relevantes para la práctica.

3.4. Desarrollo del laboratorio

3.4.1. Diseño de la solución

- Elaborar un diagrama UML que represente el funcionamiento de la aplicación de prueba. Puede utilizarse un diagrama de secuencia o de actividades que muestre el inicio de sesión, la validación de credenciales, el registro del evento y el bloqueo.
- Elaborar un diagrama de red con los dos equipos de usuario, los servidores Apache y NGINX y la máquina de monitoreo con OWASP ZAP.
- Describir la función de cada equipo y los flujos de comunicación entre los componentes.

3.4.2. Configuración de Apache

- Documentar la instalación y configuración.
- Mostrar la publicación de la aplicación de prueba.
- Identificar la ubicación de los registros y presentar capturas de la configuración relevante.

3.4.3. Configuración de NGINX

- Documentar la instalación y configuración.
- Mostrar la publicación de la misma aplicación de prueba.
- Identificar la ubicación de los registros y presentar capturas de la configuración relevante.

3.4.4. Aplicación de prueba

Implementar y documentar las siguientes funcionalidades:

- Formulario de inicio de sesión disponible en ambos servidores.
- Validación de una cuenta ficticia.
- Registro de intentos fallidos y exitosos.
- Bloqueo temporal después de tres intentos fallidos consecutivos.
- Mensaje informativo cuando la cuenta esté bloqueada.
- Registro de la activación y finalización del bloqueo.

No registrar contraseñas, tokens ni otros secretos en los archivos de auditoría.

3.4.5. Configuración de OWASP ZAP

- Explicar la configuración utilizada para observar el tráfico HTTP del laboratorio.
- Mostrar las solicitudes y respuestas relacionadas con la autenticación.
- Identificar los campos y resultados relevantes para el análisis.
- Incluir capturas de pantalla con una breve explicación de cada evidencia.

3.5. Análisis de resultados

3.5.1. Análisis de registros

Recopilar y analizar los registros de OWASP ZAP, Apache, NGINX y la aplicación de prueba.

Identificar, cuando la información esté disponible:

- Número de intentos exitosos y fallidos.
- Fecha y hora de los eventos.
- Direcciones IP de origen observadas.
- Repetición y secuencia de los intentos.
- Activación del bloqueo temporal.
- Diferencias entre las solicitudes observadas por ZAP y los eventos registrados por los servidores y la aplicación.

Distinguir entre las evidencias observadas y las interpretaciones realizadas. Una dirección IP, por sí sola, no permite concluir que un intento proviene de un atacante ni determinar si su origen es interno o externo sin información adicional de la red.

3.5.2. Matriz de riesgos inicial

Elaborar una matriz que incluya, como mínimo:

- Activo o activos afectados.
- Amenaza.
- Vulnerabilidad.

- Escenario de riesgo.
- Impacto.
- Probabilidad.
- Nivel de riesgo inherente.
- Controles existentes, si los hubiera.

Los activos deben estar identificados de forma concreta, por ejemplo: cuenta de usuario, aplicación de autenticación, registros de acceso o servidor web. No se considerarán suficientes expresiones genéricas como «sistema» o «plataforma» sin especificar qué recurso se encuentra expuesto y por qué.

3.5.3. Matriz de riesgos residual

Actualizar la matriz después de implementar los controles. Para cada riesgo, indicar:

- Control implementado.
- Relación con ISO/IEC 27005 y la función o categoría pertinente de NIST CSF 2.0.
- Evidencia de funcionamiento.
- Probabilidad e impacto después del control.
- Nivel de riesgo residual.
- Riesgo que permanece y acciones adicionales recomendadas.

Utilizar la misma escala y metodología de valoración en ambas matrices para que la comparación sea válida. La aplicación de un control no implica que el riesgo desaparezca automáticamente.

3.5.4. Comparación antes y después

Presentar una tabla de resultados que permita comprobar:

- Intentos fallidos ejecutados.
- Intentos registrados correctamente.
- Bloqueo activado al tercer intento fallido consecutivo.
- Resultado de un intento con credenciales correctas durante el bloqueo.
- Resultado después de finalizar el bloqueo.
- Diferencias observadas entre Apache y NGINX.
- Variación del nivel de riesgo estimado.

3.6. Conclusiones

Redactar conclusiones relacionadas con los objetivos y respaldadas por las evidencias obtenidas. Explicar qué se logró demostrar, qué limitaciones tuvo el laboratorio y qué riesgos permanecen.

3.7. Recomendaciones

Proponer mejoras técnicas y organizativas justificadas por los resultados, considerando la prevención del phishing, la autenticación, el monitoreo y la gestión de riesgos.

3.8. Bibliografía

Incluir las fuentes de los casos reales, la documentación oficial de Apache, NGINX y OWASP ZAP, y las referencias consultadas de ISO/IEC 27001, ISO/IEC 27005 y NIST CSF 2.0. Utilizar un formato de citación uniforme, preferentemente APA 7.ª edición.

4. Entregables

1. **Informe técnico** con la estructura indicada.
2. **Evidencias técnicas**: diagramas, capturas, extractos de registros y resultados de las pruebas.
3. **Matrices de riesgos** inicial y residual.
4. **Demostración breve** del escenario simulado, del análisis de eventos y del bloqueo temporal.

5. Consideraciones de seguridad

- Realizar todas las pruebas exclusivamente en el laboratorio autorizado.
- Utilizar cuentas ficticias y datos de prueba.
- No enviar mensajes de phishing a personas externas ni utilizar servicios públicos para capturar credenciales.
- No ejecutar pruebas contra sistemas que no formen parte del laboratorio.
- No almacenar contraseñas ni tokens en los registros.
- Mantener el bloqueo temporal y los demás controles limitados al entorno de prueba.

6. Resultado esperado

Demostrar un escenario controlado de phishing, analizar los intentos de autenticación mediante evidencias de OWASP ZAP y de los registros de los servidores, implementar y verificar un mecanismo de bloqueo temporal y justificar, mediante matrices comparables, cómo los controles seleccionados contribuyen a reducir los riesgos identificados.